Access-control requirements

Testable requirements for who can see and act on data in the portal. Each one serves part of the INN Digital Infrastructure Strategy (2026), which sets the outcomes but not these rules. They apply wherever the portal manages storage, including connected POSIX machines.

Each test names the entry it checks: a Gherkin tag in a feature file (`@AC-4 @UC-5.1`), or, in pytest, the ID at the start of the test's docstring (`AC-3.`) or a `Verifies:` line in the module's docstring. Ticket tags and markers such as `@INN-295` record where a regression was found; they are not the reason a test exists.

Open and proposed entries name the question that settles them in *INN use cases: decisions* (27 October 2026).

Status: *settled* (agreed; tests required), *proposed* (awaiting a functional decision), *open* (needed by the strategy, not yet designed; no tests yet).

ID	Requirement	Serves (strategy)	Status
AC-1	A user sees only the folders on the path to what they hold, and nothing else in those folders. This is decided per action: when browsing to read, write or delete, a folder appears if the user holds that action on it or on something inside it, so write-only and delete-only permissions stay usable. Seeing a folder doesn't allow acting on it. This applies to the screen and to the API.	5.1 postcondition ("accessible only to authorized users"); value Integrity and Ethics	settled
AC-2	Access to one item never lets a user delete or overwrite any other item.	5.1 postcondition	settled
AC-3	The backend refuses every request the user isn't authorized for, whatever the client sends.	5.1 postcondition; 4.1	settled
AC-4	A bulk action (download, delete) acts only on the items the user selected. While a filter is active, the selection holds individual files only, never folders. Decided by C3.	5.1 postcondition	proposed
AC-5	A permission names a single file, or a folder and everything in it. Its path is literal: no character in it is a pattern. Decided by B1.	4.1; 2.4 (tiered access)	proposed
AC-6	Permissions can be limited to files of a given type. Decided by C4.	2.4 (tiered access)	open
AC-7	New access to a withdrawn participant's data is blocked. Decided by D8.	5.7 main flow step 4; 4.7	open
AC-8	Access can expire with the agreement that grants it. Decided by C6.	5.8 main flow step 1; 2.4 (agreement-aware sharing)	open
AC-9	Every access is logged and attributable to a user. Decided by C2, D7.	5.1 non-functional requirements; value Integrity and Ethics	open

AC-4 and AC-5 await the permission-model decisions. AC-4's filter rule is the current behaviour; the alternative under review would let a folder whose own name matches the filter be selected as a whole.